Chính sách mật khẩu và xác thực (phiên bản 1)

Phiên bản: 1.0 | Ngày hiệu lực: 01/01/2022 | Hết hiệu lực: 31/12/2023 | Đơn vị ban hành: Khối Công nghệ thông tin (giả định)

1. Thông tin kiểm soát tài liệu

Hạng mục	Nội dung
Mã tài liệu	SYN-D08a
Đơn vị sở hữu	Khối Công nghệ thông tin (giả định)
Người phê duyệt	Giám đốc Công nghệ thông tin
Đối tượng áp dụng	Toàn bộ nhân sự và bên thứ ba được cấp tài khoản công ty
Phân loại	Nội bộ
Ghi chú	Tài liệu giả lập để kiểm thử, không phải chính sách VSF đã xác nhận

Phiên bản này áp dụng trong giai đoạn từ ngày 01/01/2022 đến hết ngày 31/12/2023 và đã hết hiệu lực sau ngày 31/12/2023. Phiên bản 2 của Chính sách mật khẩu và xác thực là bản kế tiếp và thay thế phiên bản này.

2. Mục đích, phạm vi và căn cứ

2.1 Mục đích

Chính sách này đặt ra yêu cầu tối thiểu đối với mật khẩu và việc xác thực người dùng trên các hệ thống của công ty nhằm giảm nguy cơ tài khoản bị đoán, bị đánh cắp hoặc bị lạm dụng. Tài khoản là cửa ngõ vào dữ liệu công ty, nên việc bảo vệ tài khoản là trách nhiệm chung của mọi nhân sự.

2.2 Phạm vi và đối tượng áp dụng

Chính sách áp dụng cho mọi tài khoản do công ty cấp, gồm tài khoản email, tài khoản đăng nhập máy tính, tài khoản VPN, tài khoản hệ thống nội bộ và tài khoản của nhà thầu được cấp quyền tạm thời. Chính sách áp dụng cho nhân viên chính thức, nhân viên thử việc, thực tập sinh và các bên thứ ba có tài khoản.

2.3 Căn cứ và tài liệu liên quan

- Nội quy lao động: quy định về bảo mật thông tin và xử lý vi phạm.
- Chính sách phân loại dữ liệu: xác định mức độ nhạy cảm của dữ liệu mà tài khoản được truy cập.
- Quy trình báo cáo sự cố bảo mật: cách báo khi nghi ngờ tài khoản bị chiếm quyền.
- Sổ tay nhân viên: phần tóm tắt về an toàn thông tin cho nhân sự mới.

3. Định nghĩa và thuật ngữ

Thuật ngữ	Ý nghĩa
Mật khẩu	Chuỗi ký tự bí mật dùng để chứng minh người dùng là chủ tài khoản
Xác thực nhiều yếu tố (MFA)	Xác thực bằng từ hai yếu tố trở lên, ví dụ mật khẩu và mã xác nhận trên điện thoại
Mật khẩu tạm	Mật khẩu do hệ thống hoặc IT cấp khi mở tài khoản hoặc khôi phục
Khóa tài khoản	Trạng thái tạm thời ngăn đăng nhập sau nhiều lần nhập sai liên tiếp
Tài khoản đặc quyền	Tài khoản có quyền quản trị hoặc quyền thay đổi cấu hình hệ thống
Tài khoản dịch vụ	Tài khoản dùng cho ứng dụng hoặc tác vụ tự động, không gắn với một người

4. Vai trò và trách nhiệm

Vai trò	Trách nhiệm chính	Ghi chú
Người dùng	Tạo mật khẩu đúng yêu cầu, không chia sẻ, đổi đúng hạn	Chịu trách nhiệm về tài khoản của mình
Quản lý trực tiếp	Nhắc nhở đội nhóm tuân thủ, xác nhận nhu cầu quyền	Không được giữ mật khẩu của nhân sự
IT Helpdesk	Cấp mật khẩu tạm, khôi phục tài khoản, hỗ trợ MFA	Xác minh danh tính trước khi khôi phục
Khối Công nghệ thông tin	Cấu hình hệ thống áp dụng chính sách, duy trì tài liệu	Chủ sở hữu tài liệu
Trực SOC	Tiếp nhận báo cáo tài khoản bị chiếm quyền	Xử lý theo quy trình sự cố

5. Yêu cầu mật khẩu

Mật khẩu có tối thiểu 8 ký tự và phải đổi 180 ngày một lần.

5.1 Độ dài và độ phức tạp

Ngoài độ dài tối thiểu 8 ký tự, mật khẩu nên kết hợp chữ và số. Chính sách khuyến khích dùng cụm từ gồm nhiều từ dễ nhớ nhưng khó đoán thay cho một từ đơn. Hệ thống từ chối các mật khẩu quá đơn giản như chuỗi số liên tiếp hoặc tên đăng nhập.

5.2 Thời hạn đổi mật khẩu

Mật khẩu phải được đổi 180 ngày một lần. Hệ thống nhắc nhân sự đổi mật khẩu trước ngày hết hạn 14 ngày. Nếu quá hạn mà chưa đổi, tài khoản bị yêu cầu đổi mật khẩu ngay ở lần đăng nhập kế tiếp. Mật khẩu mới không được trùng với mật khẩu hiện tại.

5.3 Mật khẩu tạm

Mật khẩu tạm do IT cấp chỉ dùng để đăng nhập lần đầu và phải được đổi ngay ở lần đăng nhập đầu tiên. Nhân sự không dùng lại mật khẩu tạm làm mật khẩu chính và không chuyển tiếp mật khẩu tạm qua tin nhắn hoặc email cho người khác.

5.4 Điều không được làm

- Không chia sẻ mật khẩu với đồng nghiệp, quản lý, IT hoặc bất kỳ ai, kể cả khi được đề nghị qua điện thoại hoặc tin nhắn.
- Không ghi mật khẩu lên giấy dán ở bàn làm việc hoặc lưu trong tệp văn bản không được bảo vệ.
- Không dùng mật khẩu công ty cho tài khoản cá nhân như mạng xã hội hoặc mua sắm trực tuyến.
- Không dùng thông tin dễ đoán như ngày sinh, số điện thoại hoặc tên người thân.

6. Xác thực nhiều yếu tố

Xác thực nhiều yếu tố (MFA) được khuyến nghị nhưng chưa bắt buộc.

6.1 Phạm vi khuyến nghị

Công ty khuyến nghị nhân sự bật MFA cho email, VPN và các hệ thống chứa dữ liệu Bí mật. Nhân sự có tài khoản đặc quyền được khuyến nghị mạnh bật MFA cho mọi tài khoản của mình. Vì MFA chưa bắt buộc, tài khoản không bật MFA vẫn được sử dụng bình thường nhưng người dùng chịu rủi ro cao hơn.

6.2 Phương thức và hỗ trợ

- Mã xác nhận gửi qua ứng dụng xác thực trên điện thoại.

- Mã xác nhận gửi qua tin nhắn khi không thể dùng ứng dụng xác thực.
- IT Helpdesk hướng dẫn bật MFA khi nhân sự yêu cầu qua email it-helpdesk@vsf-demo.example hoặc cổng IT.
- Khi đổi điện thoại hoặc mất điện thoại đã đăng ký MFA, nhân sự thông báo cho IT Helpdesk để đăng ký lại thiết bị.

7. Khóa tài khoản và khôi phục

7.1 Khóa tài khoản

Tài khoản bị khóa tạm thời 30 phút sau 10 lần nhập sai mật khẩu liên tiếp. Sau thời gian khóa, người dùng có thể đăng nhập lại. Việc khóa nhằm ngăn việc dò mật khẩu và không phải là hình thức kỷ luật.

7.2 Khôi phục mật khẩu

1. Người dùng liên hệ IT Helpdesk qua email it-helpdesk@vsf-demo.example hoặc cổng IT và nêu tên tài khoản.
2. IT Helpdesk xác minh danh tính bằng thông tin đã đăng ký, không xác minh bằng mật khẩu cũ.
3. IT Helpdesk cấp mật khẩu tạm qua kênh đã đăng ký của người dùng.
4. Người dùng đăng nhập và đổi mật khẩu ngay theo yêu cầu ở phần Mật khẩu tạm.
5. Nếu nghi ngờ tài khoản bị chiếm quyền, người dùng báo Trực SOC theo Quy trình báo cáo sự cố bảo mật thay vì chỉ đổi mật khẩu.

8. Lưu trữ và bảo vệ mật khẩu

Mật khẩu được hệ thống lưu ở dạng băm, không lưu dạng văn bản thuần. Nhân viên IT không thể xem mật khẩu của người dùng. Nếu người dùng cần ghi nhớ nhiều mật khẩu, nên dùng công cụ quản lý mật khẩu do công ty cho phép thay vì ghi ra giấy.

Tài khoản đặc quyền và tài khoản dịch vụ tuân thủ các yêu cầu như tài khoản thông thường và phải có người chịu trách nhiệm được chỉ định. Khi người chịu trách nhiệm nghỉ việc hoặc chuyển vị trí, mật khẩu của tài khoản dịch vụ cần được đổi.

9. Vi phạm và xử lý

Vi phạm chính sách được xử lý theo Nội quy lao động. Việc chia sẻ mật khẩu hoặc để người khác dùng tài khoản của mình là vi phạm nghiêm trọng. Khi việc vi phạm gây lộ dữ liệu, công ty có thể xem xét trách nhiệm cá nhân theo mức độ thiệt hại.

Hành vi	Mức độ	Cách xử lý
Không đổi mật khẩu đúng hạn	Nhẹ	Nhắc nhở và yêu cầu đổi ngay
Ghi mật khẩu ở nơi dễ thấy	Trung bình	Nhắc nhở bằng văn bản
Chia sẻ mật khẩu cho người khác	Nghiêm trọng	Xử lý theo Nội quy lao động
Cố ý dò mật khẩu tài khoản của người khác	Nghiêm trọng	Xử lý kỷ luật và báo cáo sự cố

10. Câu hỏi thường gặp

Hỏi: Mật khẩu cần tối thiểu bao nhiêu ký tự? Đáp: Tối thiểu 8 ký tự theo chính sách này.

Hỏi: Bao lâu phải đổi mật khẩu? Đáp: 180 ngày một lần; hệ thống nhắc trước ngày hết hạn 14 ngày.

Hỏi: MFA có bắt buộc không? Đáp: Chưa. MFA được khuyến nghị nhưng chưa bắt buộc.

Hỏi: Nhập sai mật khẩu nhiều lần thì sao? Đáp: Tài khoản bị khóa tạm thời 30 phút sau 10 lần nhập sai liên tiếp.

Hỏi: Tôi quên mật khẩu thì liên hệ ai? Đáp: IT Helpdesk qua it-helpdesk@vsf-demo.example; IT xác minh danh tính rồi cấp mật khẩu tạm.

Hỏi: Tôi có thể đưa mật khẩu cho đồng nghiệp để làm hộ công việc không? Đáp: Không. Chia sẻ mật khẩu là vi phạm nghiêm trọng.

Hỏi: Mật khẩu tạm dùng đến khi nào? Đáp: Chỉ dùng để đăng nhập lần đầu và phải đổi ngay ở lần đăng nhập đầu tiên.

Hỏi: Tôi nghi tài khoản bị chiếm quyền thì làm gì? Đáp: Báo Trực SOC qua soc-oncall@vsf-demo.example theo Quy trình báo cáo sự cố bảo mật.

11. Phụ lục

11.1 Phụ lục A. Danh sách kiểm tra cho người dùng

- Mật khẩu có ít nhất 8 ký tự và kết hợp chữ với số.
- Mật khẩu công ty không dùng cho tài khoản cá nhân.
- Đã bật MFA cho email và VPN (khuyến nghị).
- Không ghi mật khẩu ở nơi dễ thấy.
- Biết cách liên hệ IT Helpdesk khi quên mật khẩu.

11.2 Phụ lục B. Mẫu email yêu cầu khôi phục tài khoản

Tiêu đề: Đề nghị khôi phục mật khẩu - [Tên tài khoản]. Nội dung: Kính gửi IT Helpdesk, tôi không đăng nhập được tài khoản [tên tài khoản] do quên mật khẩu. Tôi đề nghị xác minh và hỗ trợ cấp mật khẩu tạm qua kênh đã đăng ký.

12. Lịch sử sửa đổi

Phiên bản	Ngày	Nội dung thay đổi
1.0	2022-01-01	Ban hành lần đầu chính sách mật khẩu và xác thực